

GRC REMEDIATION REPORT • CONFIDENTIAL

Insider Threat & Unauthorised Access Remediation Framework

Organisation: Inland Revenue Service | Classification: Restricted | Prepared: May 2026

INCIDENT SUMMARY

THREAT TYPE

Insider

Malicious ex-employee with retained privileged access to taxpayer-facing systems

RISK LEVEL

Critical

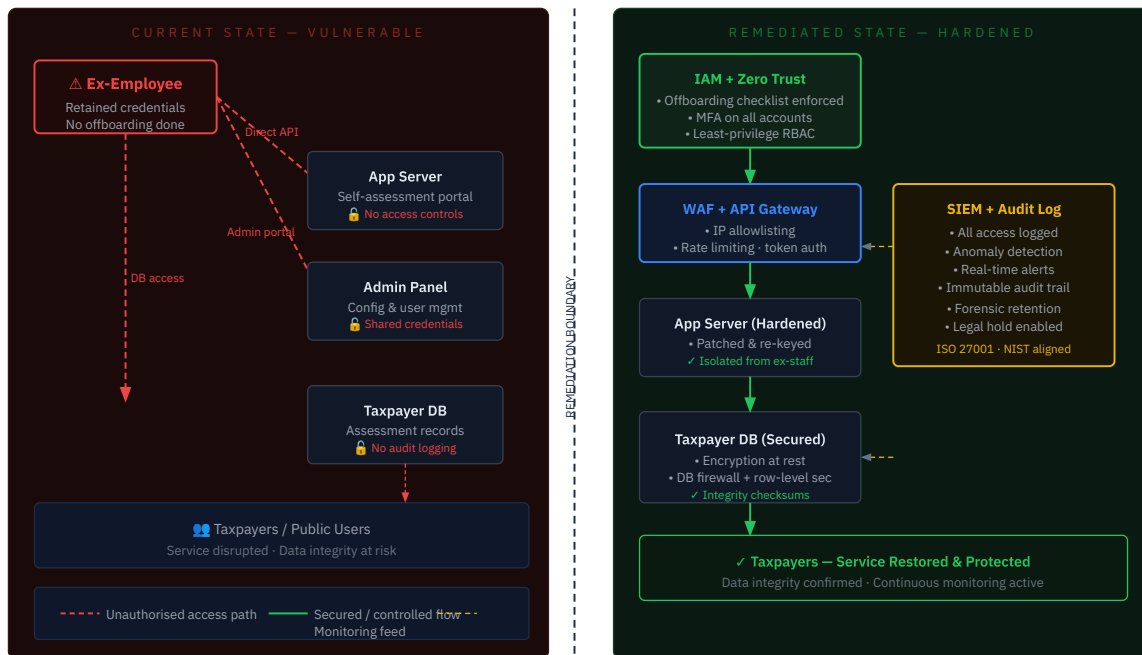
Active sabotage: data manipulation, service disruption, potential data breach

GRC RESPONSE

4-Phase

Immediate containment → investigation → hardening → continuous monitoring

ACCESS CONTROL FAILURE & REMEDIATION ARCHITECTURE



GRC FRAMEWORK RESPONSE



Governance

- Establish a formal Offboarding Policy with mandatory access revocation within 1 hour of termination
- Define Privileged Access Management (PAM) policy requiring approval workflows for all admin credentials
- Assign a Data Owner and System Owner for each application component
- Conduct an emergency Board/leadership-level incident review
- Update the Acceptable Use & Access Control Policy to cover contractor/developer roles
- Engage legal counsel to assess criminal liability and pursue prosecution if warranted



Risk Management

- Classify this as a Critical insider threat incident on the risk register
- Perform full threat modelling of all systems the ex-employee had access to
- Assess data integrity: audit all DB changes made post-separation date
- Evaluate regulatory breach exposure (data protection laws, taxpayer confidentiality)
- Engage cyber insurance provider and notify relevant regulatory body if a breach occurred
- Implement ongoing insider threat monitoring as a permanent risk control



Compliance

- Map controls to ISO 27001 A.9 (Access Control) and A.16 (Incident Management)
- Align with NIST SP 800-53 AC-2 (Account Management) and IR-4 (Incident Handling)
- Ensure data protection obligations met under applicable privacy legislation
- Produce mandatory incident report for relevant oversight body or tax authority regulator
- Conduct post-incident compliance audit with independent third party
- Schedule quarterly access reviews as a compliance standing requirement

PHASED REMEDIATION ACTION PLAN

01IMMEDIATE
(0-24 HRS)**Emergency Containment**

- Revoke ALL ex-employee credentials immediately
- Rotate API keys, service account passwords & tokens
- Block IP addresses associated with ex-employee
- Force-expire all active sessions
- Preserve all system logs for forensic investigation
- Notify incident response team & senior management
- Enable emergency change freeze on the application

02SHORT TERM
(1-7 DAYS)**Investigation & Damage Assessment**

- Forensic audit of all DB changes since departure date
- Review git history & deployment logs for backdoors
- Conduct full vulnerability scan of the application
- Implement MFA on all remaining accounts
- Deploy Web Application Firewall (WAF)
- Engage legal for potential criminal referral
- Notify affected taxpayers if data was compromised

03MEDIUM TERM
(1-4 WEEKS)**Hardening & Policy Reform**

- Implement Role-Based Access Control (RBAC)
- Deploy SIEM with insider threat detection rules
- Separate environments: dev / staging / production
- Enforce least-privilege principle across all systems
- Formalise offboarding SOP with mandatory checklist
- Introduce PAM solution for privileged accounts
- Conduct security awareness training for all staff

04

LONG TERM
(1-3
MONTHS)

Continuous Monitoring & Governance Maturity

Quarterly access reviews by system owners

Annual third-party penetration testing

Automated user access certification process

Immutable audit logging with legal hold capability

Embed GRC into SDLC for all future development

Achieve ISO 27001 certification as a target

Board-level cyber risk reporting cadence

KEY CONTROLS & RISK REGISTER

CONTROL	FRAMEWORK REF	RISK ADDRESSED	PRIORITY	OWNER
Immediate credential revocation	ISO 27001 A.9.2.6 / NIST AC-2	Ongoing unauthorised access	CRITICAL	IT Security / HR
MFA enforcement	NIST IA-2 / ISO A.9.4	Credential compromise	HIGH	IT Security
SIEM + audit logging	ISO A.12.4 / NIST AU-2	Undetected future attacks	HIGH	SOC / IT Ops
Least-privilege RBAC	ISO A.9.1 / NIST AC-6	Excessive access rights	HIGH	IT Security
Offboarding SOP	ISO A.7.3 / NIST PS-4	Recurrence of this scenario	HIGH	HR / CISO
WAF & API Gateway	NIST SC-7 / ISO A.13	External attack surface	MEDIUM	Network / IT
Privileged Access Management	ISO A.9.4.4 / NIST AC-17	Uncontrolled admin accounts	MEDIUM	IT Security
Penetration testing (annual)	ISO A.14.2.8 / NIST CA-8	Unknown vulnerabilities	MEDIUM	CISO / Third Party
Quarterly access reviews	ISO A.9.2.5 / NIST AC-2(7)	Access creep over time	ONGOING	System Owners
Legal referral / prosecution	Computer Misuse Act / local law	Deterrence & accountability	HIGH	Legal / Management

INLAND REVENUE SERVICE · GRC REMEDIATION FRAMEWORK ·
RESTRICTED

Prepared: May 2026 · Reference: IRS-
SEC-2026-001